COMPTIA SECURITY+ SY0-701 | DOMAIN 1 · GENERAL SECURITY CONCEPTS (12%)

Security+ 1.2 · Non-repudiation

Mestre CyberSec · **Lesson 1.2 — Non-repudiation** (7:57) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Não-repúdio: prova irrefutável de QUEM fez — impossível negar depois. Implementação: hash do dado cifrado com a chave PRIVADA de quem assina (assinatura digital). Qualquer um valida com a pública. Base de contrato digital, transação, log de auditoria.

💡 Key Exam Highlights & Critical Concepts

- Hash só prova integridade; assinatura prova integridade + AUTOR
- Assimétrico: privada assina, pública valida
- Prova de não-Repúdio: 'não foi eu' é impossível de alegar após assinado

🎯 Exam Tips & Typical CompTIA Scenarios

- Se a questão cita 'cannot deny'/'cannot dispute' = non-repudiation
- Qual algoritmo: RSA assinatura (não AES — AES é simétrico, sem autor único)

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 1.2 — Non-repudiation)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Non-repudiation (N/A)

A security objective ensuring that a party cannot deny having performed an action, such as signing a message or approving a transaction. It provides irrefutable proof of origin or authorship.

⚠️ ***Exam Trap:*** *Gatilho: 'cannot deny', 'cannot dispute', 'prova de autoria'. Não confunda com integridade: hash sozinho não dá não-repúdio.*

• Digital Signature (N/A)

Cryptographic technique that hashes data and encrypts/signs the hash with the sender's private key. It proves integrity plus origin/authentication and provides non-repudiation.

⚠️ ***Exam Trap:*** *Assinatura digital = integridade + autor. Se a questão pedir 'não-repúdio', a resposta normalmente é assinatura digital, não apenas hash.*

• Hash (Hash Function) (N/A)

A one-way function that produces a fixed-length digest from data; it verifies integrity by detecting changes. Alone, it does not prove who created or sent the data.

⚠️ ***Exam Trap:*** *Hash = integridade apenas. Se a questão exige autor/não-repúdio, precisa de assinatura digital, não só hash.*

• Asymmetric Encryption (N/A)

Encryption using a key pair: a public key and a private key. For non-repudiation, the signer uses the private key and verifiers use the matching public key.

⚠️ ***Exam Trap:*** *Assimétrico: privada assina, pública valida. Não use AES para assinatura/não-repúdio; AES é simétrico e não identifica autor único.*

• Private Key (N/A)

The secret key in an asymmetric key pair, known only to its owner. It creates digital signatures and decrypts data encrypted with the corresponding public key.

⚠️ ***Exam Trap:*** *Privada do signatário assina; nunca é compartilhada. Se a privada não for exclusiva, a alegação 'não foi eu' pode ser possível.*

• Public Key (N/A)

The freely distributable key in an asymmetric key pair. It verifies digital signatures and encrypts data for the holder of the matching private key.

⚠️ ***Exam Trap:*** *Pública valida assinatura; não dá não-repúdio se usada para assinar, pois não é exclusiva do autor. Confirme sempre privada assina / pública valida.*

• RSA (Rivest-Shamir-Adleman)

An asymmetric cryptographic algorithm commonly used for digital signatures and key exchange. In Security+ non-repudiation questions, RSA signatures prove authorship via private-key signing and public-key verification.

⚠️ ***Exam Trap:*** *Se pedir algoritmo para assinatura/não-repúdio, pense RSA/ECDSA/DSA (assimétricos). AES é simétrico e não prova autor único.*

• Integrity (N/A)

A security goal ensuring data has not been altered or tampered with. Hashing proves integrity, but non-repudiation requires proof of the author as well.

⚠️ ***Exam Trap:*** *Integridade não é não-repúdio. Se a pergunta diz 'cannot deny', não basta hash/checksum; precisa de assinatura digital.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Non-repudiation: The Irrefutable Legal and Technical Proof of Authorship

🏠 **Real-World Analogy:** A real estate property transfer signed in person before a licensed notary public, validated by biometric thumbprint, government photo ID, and recorded in the permanent municipal deed book. The seller cannot later stand before a judge and dispute: 'I never sold that home, someone forged my identity.'

🔍 **Root Cause & Background:** If an architecture relies solely on simple passwords or shared symmetric keys, a rogue user executing fraudulent transactions can claim plausible deniability ('someone must have stolen my password' or 'the database administrator manipulated the records'). Non-repudiation completely eliminates deniability.

🛡️ **GRC Auditor Perspective:** In regulatory compliance audits (SOX section 404, HIPAA, FINRA/SEC rules), auditors inspect financial release approvals, production code commits, and digital contracts to ensure they possess legally binding, forensically provable non-repudiation.

⚠️ **How CompTIA Tests This:** Dead giveaway exam phrases: 'Cannot deny having sent the message', 'Sender cannot dispute the transaction', 'Provides irrefutable proof of origin'. CompTIA target answer: Non-repudiation via Digital Signatures.

📌 Digital Signatures: Asymmetric Cryptography in Action

🏠 **Real-World Analogy:** The sovereign's unique signet ring pressed into hot wax upon an executive decree. Every governor across the empire possesses a certified replica of the royal coat of arms (Public Key) to authenticate the seal, but only the emperor holds the physical signet ring (Private Key) capable of embossing that wax.

🔍 **Root Cause & Background:** Symmetric cryptography (like AES) relies on a shared secret known to both parties, meaning the recipient could theoretically forge the transmission. To guarantee indisputable individual authorship, the signing key must reside strictly and exclusively with the author.

🛡️ **GRC Auditor Perspective:** PKI auditors examine private key lifecycle governance: ensuring enterprise CA and executive signing keys are protected inside FIPS 140-2/3 validated Hardware Security Modules (HSMs) and validating active Certificate Revocation Lists (CRL) and OCSP stapling.

⚠️ **How CompTIA Tests This:** CompTIA's golden asymmetric rule: The sender creates a digital signature by encrypting the document's hash with their own PRIVATE KEY. The recipient validates the signature using the sender's PUBLIC KEY. EXAM TRAP: Encrypting with recipient's public key provides Confidentiality, NOT Non-repudiation!

📌 Secure Timestamping (RFC 3161): Proving WHEN the Event Occurred

🏠 **Real-World Analogy:** A proof-of-life photograph holding today's printed daily newspaper, or a court clerk's atomic-clock synchronized physical protocol stamp. It is not enough to prove you signed a financial transfer; you must prove it was signed at 2:00 PM on Tuesday before the account was frozen by a court injunction.

🔍 **Root Cause & Background:** If a signing certificate expires or is revoked years later, a dishonest signer could argue that a valid historical contract was actually forged after key compromise. An RFC 3161 Time Stamping Authority (TSA) provides mathematically verifiable proof that the signature existed prior to revocation.

🛡️ **GRC Auditor Perspective:** Auditors verify secure Network Time Protocol (NTP) synchronization and integration with accredited RFC 3161 Time Stamping Authorities (TSA) for legally binding long-term digital record retention (PAdES / XAdES compliance).

⚠️ **How CompTIA Tests This:** Exam scenario cue: 'Prove that a digital transaction was signed prior to the signing certificate being compromised, revoked, or expired'. Target answer: Secure Timestamping / RFC 3161 TSA.

📌 Immutable Audit Logs and WORM Storage

🏠 **Real-World Analogy:** Engraving executive decrees into granite with a chisel or burning financial ledgers onto a write-once optical CD-R. Once the laser physically burns pits into the polycarbonate disc, nobody on earth—not even the IT administrator or corporate CEO—can modify or delete a single byte.

🔍 **Root Cause & Background:** Attackers and rogue insiders obtaining root or Domain Admin privileges routinely execute scripts to wipe operating system event logs, erasing digital footprints to prevent forensic attribution and evade prosecution.

🛡️ **GRC Auditor Perspective:** In financial forensics audits (SEC Rule 17a-4, SOX), auditors mandate WORM (Write Once, Read Many) storage, such as cloud object stores configured with Object Lock in Compliance Mode, where even root account credentials cannot purge audit records prior to statutory retention expiry.

⚠️ **How CompTIA Tests This:** Exam scenario cue: 'Ensure that forensic logs cannot be modified, tampered with, or purged, even if an administrator account is fully compromised'. Target answer: Immutable audit logs / WORM storage.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
User claims they never authorized a multimillion-dollar wire transfer sent from their account	**Non-repudiation (via Digital Signature)**
How is a digital signature generated to prove origin and message integrity?	**Document hash encrypted with sender's Private Key**
How does a recipient verify that a received digital signature is authentic?	**Decrypts signature using sender's Public Key and verifies matching hash**
Proving a digital contract was executed before signer's certificate was revoked	**Secure Timestamping (RFC 3161 TSA)**
Preventing a rogue root administrator from purging audit logs following a compromise	**Immutable Logging / WORM (Write Once, Read Many)**
What is the primary difference between a simple Hash and a Digital Signature?	**Hash provides only Integrity; Digital Signature provides Integrity + Authorship + Non-repudiation**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A bank is designing a system for corporate customers to authorize high-value wire transfers online. The bank wants to ensure that after a transfer is submitted, the customer cannot later deny having authorized it. Which control should the bank require for each transfer request?

A) An RSA digital signature generated with the customer's private key and verified with the customer's public key

B) Encryption of the transfer request with the bank's public key

C) A SHA-256 hash of the transfer request stored in the bank's database

D) A shared HMAC secret generated jointly by the bank and the customer

QUESTION 2 · EXAM SCENARIO

A contract management platform receives an electronically signed agreement. The recipient needs to prove that the signature was created by the sender and that the sender cannot deny signing it. Which key should the recipient use to validate the signature?

A) Recipient's private key

B) Sender's public key

C) Sender's private key

D) Certificate authority's private key

QUESTION 3 · EXAM SCENARIO

Two departments share a symmetric HMAC key to protect audit log entries. During a dispute, one department claims the other could have modified the logs because both know the same key. Why does this HMAC design fail to provide non-repudiation?

A) HMAC does not use a hash function

B) Either department with the shared key could generate a valid HMAC

C) HMAC encrypts the logs with a private key

D) HMAC provides confidentiality but not integrity

QUESTION 4 · EXAM SCENARIO

A software company distributes security patches over the Internet. Customers must verify that a patch really came from the company and that the company cannot later deny publishing it. What should the company do?

A) Sign the patch hash with the company's private key

B) Encrypt the patch with each customer's public key

C) Publish the patch hash on an HTTP website

D) Compress the patch with a password shared by customers

QUESTION 5 · EXAM SCENARIO

An administrator changes a firewall rule and later denies making the change. The organization's change-management system records each change and requires administrators to use personal cryptographic credentials. Which evidence would best allow investigators to prove which administrator authorized the change?

A) A valid digital signature on the change record verified with that administrator's public key

B) A symmetric session key used during the administrator's SSH login

C) A firewall log showing the source IP address of the administrator's workstation

D) A password hash stored in the directory service for the administrator

QUESTION 6 · EXAM SCENARIO

A healthcare provider sends an audit report to a regulator. The regulator requires assurance that the report was created by the provider's compliance officer and that the officer cannot later claim it was forged. Which cryptographic operation should the compliance officer perform?

A) Encrypt the report with the regulator's public key

B) Hash the report and encrypt the hash with the compliance officer's private key

C) Hash the report and store the hash in a local database

D) Encrypt the report with a symmetric key shared with the regulator

QUESTION 7 · EXAM SCENARIO

A company wants to implement digital signatures for its executives so that signed policy documents can be verified by any employee. Which statement describes the correct key usage?

A) Executives sign with their public keys; employees verify with private keys

B) Executives sign with their private keys; employees verify with the corresponding public keys

C) Executives sign with a shared symmetric key; employees verify with the same key

D) Executives sign with the CA's private key; employees verify with the CA's public key

QUESTION 8 · EXAM SCENARIO

A developer commits source code to a repository. Management wants to ensure that the developer cannot later deny authoring a specific commit. Which mechanism should be enabled?

A) Sign each commit with the developer's private key

B) Encrypt each commit with the repository server's public key

C) Require the developer to use a shared team password for commits

D) Store only the MD5 hash of each commit in the repository

QUESTION 9 · EXAM SCENARIO

A supplier and a buyer finalize a purchase agreement electronically. Both parties want to prevent the other from later denying agreement to the terms. Which implementation best meets this requirement?

A) Both parties digitally sign the hash of the agreement with their own private keys

B) Both parties encrypt the agreement with a shared AES key

C) The buyer hashes the agreement and sends the hash to the supplier

D) The supplier stores the agreement on a read-only file server

QUESTION 10 · EXAM SCENARIO

A security architect implements a control where each broker signs trade orders with a personal private key, and the platform verifies them with the broker's public key. Which security property does this control primarily provide?

A) Non-repudiation

B) Confidentiality

C) Availability

D) Obfuscation

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option A — An RSA digital signature generated with the customer's private key and verified with the customer's public key

Correct because a digital signature made with the signer's private key provides non-repudiation, since only the customer possesses that private key. Encrypting with the bank's public key provides confidentiality; a hash alone provides integrity but not origin or non-repudiation; a shared HMAC secret can be generated by either party, so it is deniable.

Question 2: Option B — Sender's public key

Correct because digital signatures are verified with the signer's public key. The sender's private key must remain secret, the recipient's private key is used for decryption or signing by the recipient, and the CA's private key signs certificates rather than the agreement.

Question 3: Option B — Either department with the shared key could generate a valid HMAC

Correct because a shared secret means both parties can create the MAC, so it cannot prove which party generated it. HMAC does use a hash function, does not encrypt with a private key, and does provide integrity and symmetric authentication, but it does not provide non-repudiation.

Question 4: Option A — Sign the patch hash with the company's private key

Correct because code signing or digital signing with the company's private key provides non-repudiation and allows customers to verify with the company's public key. Encrypting per customer does not prove origin, a hash over HTTP can be altered, and a shared password does not prove the company's origin.

Question 5: Option A — A valid digital signature on the change record verified with that administrator's public key

Correct because the digital signature binds the administrator's identity to the change record and provides non-repudiation. An SSH session key is shared or ephemeral, an IP address can be spoofed or shared, and a password hash authenticates login but does not sign the record and could be misused if compromised.

Question 6: Option B — Hash the report and encrypt the hash with the compliance officer's private key

Correct because signing the hash with the private key creates a digital signature and provides non-repudiation. Encrypting with the regulator's public key gives confidentiality, storing a local hash does not prove authorship, and a shared symmetric key is deniable.

Question 7: Option B — Executives sign with their private keys; employees verify with the corresponding public keys

Correct because the private key signs and the public key verifies. The reverse is invalid and insecure, a symmetric key does not provide non-repudiation, and the CA's key signs certificates rather than documents unless the CA itself is the signer.

Question 8: Option A — Sign each commit with the developer's private key

Correct because commit signing uses the developer's private key and verifies with the public key, providing non-repudiation. Encryption to the repository server does not prove authorship, a shared password is not unique, and a hash alone does not identify the author.

Question 9: Option A — Both parties digitally sign the hash of the agreement with their own private keys

Correct because each signature made with a private key provides non-repudiation for each party. A shared AES key is deniable, a hash alone does not sign, and a read-only server does not prove agreement by both parties.

Question 10: Option A — Non-repudiation

Correct because non-repudiation prevents denial of origin or action. Confidentiality protects against disclosure, availability ensures access, and obfuscation hides code. A digital signature with a private key is the mechanism used here.